ĐẠI HỌC THÁI NGUYÊN
TRƯỜNG ĐẠI HỌC CÔNG NGHỆ THÔNG TIN VÀ TRUYỀN THÔNG
KHOA CÔNG NGHỆ THÔNG TIN

★ ★ ★



BÁO CÁO BÀI TẬP LỚN

HỌC PHẦN: TRIỂN KHAI & QUẢN TRỊ HỆ THỐNG / DEVOPS

XÂY DỰNG VÀ TRIỂN KHAI HỆ THỐNG QUẢN LÝ KHO HÀNG

(INVENTORY MANAGEMENT SYSTEM)

ĐỀ TÀI: ĐỀ SỐ 05 | Ngành: Công nghệ thông tin

SINH VIÊN THỰC HIỆN:

Họ và tên: **Thân Phú Cường**

MSSV: **DTC245200356**

Lớp: **CNTTK23L**

GIẢNG VIÊN HƯỚNG DẪN:

Giảng viên: **TS. Vũ Văn Diện**

Môn học: **Triển khai & Quản trị Hệ thống**

Khoa: **Công nghệ thông tin**

THÁI NGUYÊN, NĂM 2026

LỜI CẢM ƠN

Em xin gửi lời cảm ơn chân thành và sâu sắc nhất đến **thầy TS. Vũ Văn Diện**, giảng viên môn học *Triển khai & Quản trị Hệ thống*, người đã tận tình truyền đạt những kiến thức quý báu, định hướng phương pháp tư duy kỹ thuật và hỗ trợ chúng em trong suốt quá trình hoàn thành bài tập lớn với đề tài: **"Xây dựng và Triển khai Hệ thống Quản lý Kho hàng (Inventory Management System)"**.

Những bài giảng chuyên sâu của thầy về kiến trúc ảo hóa container, cổng điều hướng Gateway Nginx, giải pháp giám sát chỉ số thời gian thực Prometheus – Grafana và hệ thống truy vết log tập trung Loki – Promtail đã giúp em không chỉ nắm vững lý thuyết mà còn tự tin vận dụng vào xây dựng một hạ tầng dịch vụ chuẩn mực DevOps.

Dù đã dành nhiều nỗ lực và tâm huyết để hoàn thiện đồ án một cách chỉn chu nhất, song do giới hạn về kiến thức và kinh nghiệm thực tiễn, bản báo cáo khó tránh khỏi những thiếu sót nhất định. Em rất mong tiếp tục nhận được những nhận xét, góp ý quý báu từ thầy để hệ thống ngày càng được hoàn thiện và nâng cao hơn nữa.

Kính chúc thầy luôn dồi dào sức khỏe, hạnh phúc và gặt hái được nhiều thành tựu rực rỡ trong sự nghiệp nghiên cứu và giảng dạy!

MỤC LỤC

1 Mở đầu & Tổng quan Hệ thống **1**

1.1 Đặt vấn đề & Mục tiêu Đề tài 1

1.2 Kiến trúc Tổng thể Hệ thống 2

2 Cấu trúc Mã nguồn & Quản lý trên GitHub **3**

2.1 Quy chuẩn Quản lý Mã nguồn 3

2.2 Cấu trúc Thư mục Dự án 3

2.3 Nội dung Hướng dẫn README.md 5

3 Triển khai Website Quản lý Kho & CSDL MySQL **6**

3.1 Thiết kế Cơ sở Dữ liệu MySQL 8.0 6

3.2 Chức năng Nghiệp vụ & Giao diện Website Quản lý Kho 6

3.2.1 Giao diện Đăng nhập Hệ thống (Authentication & RBAC) 6

3.2.2 Bảng Điều khiển Tổng quan (Dashboard Quản lý Kho) 7

3.2.3 Phân hệ Quản lý Hàng hóa (Products Management) 8

3.2.4 Phân hệ Quản lý Nhóm Sản phẩm (Categories) 9

3.2.5 Phân hệ Quản lý Nhà Cung cấp (Suppliers) 9

3.2.6 Phân hệ Giao dịch Nhập / Xuất Kho (Inventory Transactions) 10

3.2.7 Phân hệ Báo cáo & Thống kê Tài sản Kho (Reports) 11

3.2.8 Trung tâm Điều hành Giám sát & Sandbox Thử nghiệm LogQL 11

4 Cấu hình Nginx Reverse Proxy, Security Headers & SSL **13**

4.1 Vai trò của Nginx Reverse Proxy 13

4.2 Tạo SSL Certificate Tự ký (Self-Signed SSL) 13

4.3 Thiết lập 5 Tiêu chuẩn Security Headers trong default.conf 13

5 Giám sát Hệ thống với Prometheus & Grafana **15**

5.1 Mô hình Kéo Chỉ số (Prometheus Pull Model) 15

5.2 Dashboard Tự động Provisioning trên Grafana 15

5.3 Trạng thái Hoạt động Các Exporters trên Prometheus Targets 16
5.4 Cổng Quản trị Cơ sở Dữ liệu phpMyAdmin qua Nginx Gateway 17

6 Quản lý Log Tập trung với Loki & Promtail 18
6.1 Nguyên lý Thu thập & Xử lý Log 18
6.2 Ba Câu Truy Vấn LogQL Chuyên Sâu 18
6.2.1 Truy vấn 1: Lọc mã lỗi HTTP 4xx hoặc 5xx từ Nginx Gateway 18
6.2.2 Truy vấn 2: Thống kê tần suất request theo IP (Phát hiện DoS / Brute-force) 18
6.2.3 Truy vấn 3: Truy vết lỗi giao dịch kho hàng (Inventory Transactions) . . 19

7 Gia cố Bảo mật Hệ thống (Hardening) 20

8 Kiểm thử Hệ thống & Đánh giá Thực nghiệm 21
8.1 Mục tiêu & Phương pháp Kiểm thử 21
8.2 Bảng Ma trận Kiểm thử Thực nghiệm (Test Cases Matrix) 22

9 Kết luận & Hướng phát triển 24
9.1 Kết quả Đạt được 24
9.2 Hướng Phát triển Nâng cấp 24
Tài liệu Tham khảo 24

DANH SÁCH HÌNH VẼ

3.1 Giao diện Đăng nhập An toàn Hệ thống 7
3.2 Bảng Điều khiển Tổng quan Dashboard 8
3.3 Giao diện Quản lý Danh mục Hàng hóa 8
3.4 Giao diện Quản lý Danh mục Sản phẩm 9
3.5 Giao diện Quản lý Nhà Cung Cấp Đối Tác 10
3.6 Giao diện Quản lý Giao dịch Nhập / Xuất Kho 10
3.7 Báo cáo Thẩm định & Luân chuyển Tồn kho 11
3.8 Trung tâm Giám sát Hạ tầng DevOps & Sandbox LogQL 12

5.1 Bảng Giám sát Hệ thống & Nhật ký Tập trung trên Grafana 16
5.2 Trạng thái Hoạt động UP của các Exporter trên Prometheus 16
5.3 Giao diện Quản trị CSDL phpMyAdmin qua Nginx Gateway 17

DANH SÁCH BẢNG

2.1 Mô tả Chi tiết Các Thành phần trong Cấu trúc Thư mục Dự án 5

8.1 Bảng Ma trận Kiểm thử Thực nghiệm Toàn diện Hệ thống 22

CHƯƠNG 1: MỞ ĐẦU & TỔNG QUAN HỆ THỐNG

1.1. Đặt vấn đề & Mục tiêu Đề tài

Trong bối cảnh chuyển đổi số toàn diện và sự bùng nổ của các ứng dụng thương mại điện tử, dịch vụ chuỗi cung ứng logistics hiện đại, khối lượng giao dịch và tần suất luân chuyển hàng hóa tại các doanh nghiệp ngày càng tăng trưởng với tốc độ cấp số nhân. Với các phương pháp quản lý kho thủ công truyền thống qua sổ sách hoặc các file tính rời rạc thiếu đồng bộ, bộ phận vận hành kho liên tục đối mặt với những thách thức nghiêm trọng:

- Sai lệch số liệu tồn kho giữa thực tế và ghi nhận sổ sách.
- Chậm trễ trong điều phối hàng hóa, thiếu cơ chế cảnh báo chủ động khi hàng hóa chạm ngưỡng an toàn.
- Không kiểm soát chặt chẽ trách nhiệm luân chuyển giữa các nhân viên trong từng ca làm việc.
- Thiếu cơ chế theo dõi trạng thái tải tài nguyên máy chủ và truy vết sự cố hệ thống theo thời gian thực.

Xuất phát từ yêu cầu thực tế đó, mục tiêu của đề tài không chỉ dừng lại ở việc phát triển ứng dụng Web Quản lý Kho hàng đáp ứng trọn vẹn nghiệp vụ nghiệp vụ nhập – xuất – tồn mà còn triển khai đồng bộ theo mô hình **Chuẩn vận hành hệ thống hiện đại (DevOps / SRE / Containerization)**:

1. **Containerization:** Đóng gói độc lập toàn bộ các dịch vụ ứng dụng, cơ sở dữ liệu và công cụ quản trị bằng Docker và điều phối qua Docker Compose.
2. **Cổng bảo mật Gateway (Reverse Proxy):** Cấu hình Nginx đóng vai trò điểm chạm duy nhất, tiếp nhận lưu lượng mạng, chuyển hướng tự động HTTP sang HTTPS với chứng chỉ SSL/TLS tự ký, đồng thời thiết lập đầy đủ 5 tiêu chuẩn HTTP Security Headers.
3. **Giám sát Toàn diện (Monitoring):** Tích hợp bộ đôi Prometheus và Grafana, tự động nạp cấu hình DataSource và Dashboards giám sát tài nguyên máy chủ và cơ sở dữ liệu MySQL theo thời gian thực.
4. **Quản lý Log Tập trung (Centralized Logging):** Ứng dụng giải pháp Grafana Loki kết hợp Promtail để thu thập log thời gian thực từ Nginx và Web App, thực thi 3 câu truy vấn LogQL chuyên sâu phục vụ cảnh báo và khắc phục sự cố.
5. **Gia cố An toàn (Hardening):** Tuân thủ nghiêm ngặt các nguyên tắc bảo mật: Non-root user trong container, phân vùng mạng Docker Networks độc lập, cô lập cổng CSDL MySQL, bảo vệ biến môi trường và giới hạn tài nguyên CPU/RAM.

1.2. Kiến trúc Tổng thể Hệ thống

Hệ thống được thiết kế theo mô hình kiến trúc phân tầng dịch vụ chuẩn mực (Multi-tier Architecture), đảm bảo tính cô lập, khả năng mở rộng linh hoạt và an toàn dữ liệu:

1. **Tầng 1 – User / Client Layer:** Người dùng truy cập hệ thống thông qua các trình duyệt web bảo mật (Chrome, Edge, Firefox) thông qua giao thức HTTP/HTTPS.
2. **Tầng 2 – Reverse Proxy Gateway Layer:** Cụm Nginx tiếp nhận các kết nối mạng bên ngoài tại cổng 80 và 443. Nginx đảm nhiệm nhiệm vụ ép buộc chuyển hướng toàn bộ lưu lượng HTTP sang HTTPS bằng mã phản hồi `301 Moved Permanently`, giải mã SSL/TLS, gán các HTTP Security Headers phòng thủ và định tuyến thông minh:
    - Đường dẫn `/` chuyển tiếp lưu lượng vào Web Application (PHP).
    - Đường dẫn `/pma/` định tuyến vào cổng quản trị cơ sở dữ liệu phpMyAdmin.
    - Đường dẫn `/grafana/` chuyển tiếp tới trung tâm giám sát Grafana.
3. **Tầng 3 – Application & Storage Layer:**
    - *Web Application (PHP 8.2 / Apache):* Xử lý toàn bộ logic kho hàng (quản lý sản phẩm, danh mục, nhà cung cấp, nhập xuất kho, in ấn phiếu và xuất báo cáo).
    - *Database (MySQL 8.0):* Hệ quản trị CSDL quan hệ lưu trữ dữ liệu kho, đảm bảo tính toàn vẹn dữ liệu theo tiêu chuẩn giao dịch ACID.
    - *phpMyAdmin:* Giao diện trực quan hỗ trợ quản trị viên thao tác trực tiếp với CSDL an toàn.
4. **Tầng 4 – Monitoring & Centralized Logging Layer:**
    - *Prometheus:* Máy chủ kéo chỉ số (Pull model) thu thập metrics định kỳ từ Node Exporter (tài nguyên host), MySQL Exporter (hiệu năng CSDL) và cAdvisor (tài nguyên container).
    - *Grafana:* Trung tâm trực quan hóa các chỉ số hiệu năng và dòng nhật ký lên các bảng điều khiển trực quan.
    - *Promtail:* Agent thu gom tệp log từ Nginx (`/var/log/nginx/`) và Web App (`/var/log/app/app.log`), gắn nhãn metadata và đẩy về Loki qua API.
    - *Loki:* Hệ thống lưu trữ và đánh chỉ mục nhật ký tập trung, phục vụ truy vấn LogQL tốc độ cao.

CHƯƠNG 2: CẤU TRÚC MÃ NGUỒN & QUẢN LÝ TRÊN GITHUB

2.1. Quy chuẩn Quản lý Mã nguồn

Toàn bộ mã nguồn ứng dụng Web Quản lý kho, các tệp cấu hình hạ tầng Docker Compose, Nginx, Prometheus, Loki, Promtail và tài liệu kiểm thử được quản lý tập trung trên GitHub tuân thủ quy trình Git Workflow chuyên nghiệp:

- **Tài khoản GitHub & Repository:** Repository được khởi tạo với tên theo chuẩn Mã số Sinh viên: `cuongcoder123/DTC245200356-QLKH`.
- **Quy trình Git Commit:** Mỗi giai đoạn triển khai tương ứng với các commit rõ ràng, ghi chú chi tiết công việc hoàn thành và tuần tự theo yêu cầu đề bài (Commit 1: Nginx SSL & Headers, Commit 2: Prometheus & Grafana, Commit 3: Loki & Promtail).

2.2. Cấu trúc Thư mục Dự án

Dự án được tổ chức khoa học với cấu trúc phân tách rõ ràng giữa mã nguồn ứng dụng nghiệp vụ và các tệp cấu hình dịch vụ hạ tầng:

Sơ đồ Cây Thư mục Hệ thống

```
DTC245200356-QLKH/
├── docker-compose.yml
├── .env.example
├── README.md
├── nginx/
│   ├── nginx.conf
│   ├── conf.d/
│   │   └── default.conf
│   └── ssl/
│       ├── server.crt
│       └── server.key
├── app/
│   ├── src/ ... (Mã nguồn Website Quản lý kho: PHP/Apache)
│   └── Dockerfile
├── prometheus/
│   └── prometheus.yml
├── promtail/
│   └── promtail-config.yml
├── loki/
│   └── loki-config.yml
└── grafana/
    └── provisioning/
        ├── datasources/
        └── dashboards/
```

Thành phần / Thư mục	**Vai trò và Chức năng trong Hệ thống**
`docker-compose.yml`	Tệp điều phối trung tâm khởi chạy đồng bộ cụm 10 container dịch vụ.
`.env.example`	Tệp mẫu khai báo biến môi trường an toàn (được đưa vào `.gitignore`).
`README.md`	Cẩm nang hướng dẫn cài đặt, kiến trúc tổng thể và kiểm thử hệ thống.
`nginx/`	Cổng Gateway Reverse Proxy, chứng chỉ SSL tự ký và 5 tiêu chuẩn Security Headers.
`app/`	Mã nguồn Web Quản lý kho (PHP 8.2), Dockerfile đóng gói với Non-root user (`appuser`).
`prometheus/`	Cấu hình Scrape Metrics định kỳ 15s thu thập từ Node Exporter và MySQL Exporter.
`promtail/`	Thu gom log tệp từ Nginx và Web App, gắn nhãn định danh chuyển tiếp về Loki.
`loki/`	Kho lưu trữ và đánh chỉ mục nhật ký tập trung phục vụ các truy vấn LogQL.
`grafana/`	Tự động nạp sẵn (Provisioning) DataSource và các Dashboards giám sát trực quan.

Bảng 2.1: Mô tả Chi tiết Các Thành phần trong Cấu trúc Thư mục Dự án

2.3. Nội dung Hướng dẫn README.md

Tệp `README.md` tại thư mục gốc repository đóng vai trò cẩm nang hướng dẫn vận hành toàn diện cho đội ngũ kỹ sư và giảng viên thẩm định. Tài liệu cung cấp đầy đủ:

- Bảng tổng hợp cổng dịch vụ (Port Mapping) và đường dẫn truy cập qua Nginx Gateway.
- Hướng dẫn khởi chạy toàn bộ 10 container chỉ với một câu lệnh:

```
docker-compose up -d --build
```

- Hướng dẫn kiểm tra trạng thái hoạt động của các tiến trình container:

```
docker-compose ps
```

- Danh sách tài khoản đăng nhập mặc định cho các dịch vụ (Web App, phpMyAdmin, Grafana) và danh mục kiểm thử thực nghiệm.

CHƯƠNG 3: TRIỂN KHAI WEBSITE QUẢN LÝ KHO & CSDL MYSQL

3.1. Thiết kế Cơ sở Dữ liệu MySQL 8.0

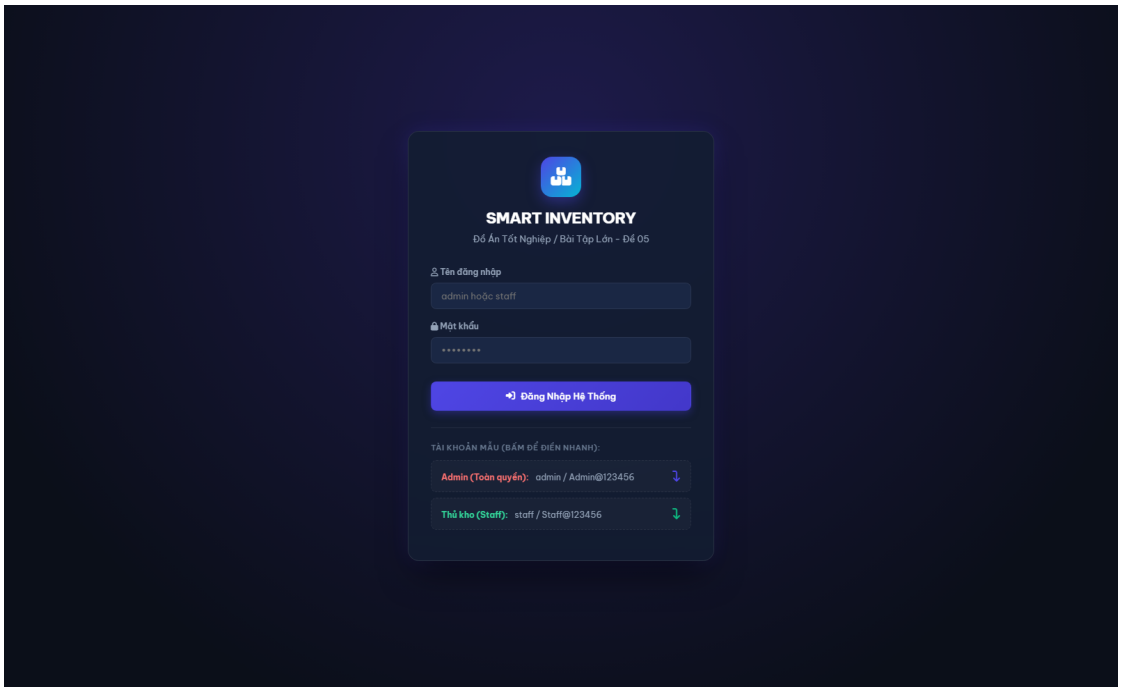
Cơ sở dữ liệu `inventory_db` được thiết kế chuẩn hóa bậc 3 (3NF) gồm 6 bảng thực thể quan hệ chặt chẽ:

1. `users`: Quản lý danh sách tài khoản người dùng, băm mật khẩu với thuật toán `BCRYPT`, phân quyền theo vai trò (`admin` – Quản trị viên toàn quyền, `staff` – Thủ kho phụ trách nhập xuất).
2. `categories`: Quản lý các nhóm danh mục phân loại mặt hàng trong kho (Linh kiện máy tính, Thiết bị mạng, Thiết bị ngoại vi, Phụ kiện, Thiết bị lưu trữ).
3. `suppliers`: Lưu trữ hồ sơ các nhà cung cấp đối tác chiến lược (tên doanh nghiệp, mã số thuế, hotline, email liên hệ và địa chỉ trụ sở).
4. `products`: Quản lý chi tiết từng SKU sản phẩm: mã hàng, danh mục trực thuộc, đơn vị tính, giá nhập dự toán, giá bán niêm yết, số lượng tồn kho thực tế và ngưỡng tồn kho tối thiểu (`min_stock`).
5. `inventory_transactions`: Lưu vết toàn bộ lịch sử các giao dịch biến động kho hàng (Nhập kho – `IMPORT`, Xuất kho – `EXPORT`), mã phiếu, người phụ trách, đối tác và ghi chú nghiệp vụ.
6. `system_logs`: Lưu nhật ký hoạt động hệ thống nội bộ, phục vụ kiểm toán bảo mật và đối soát chéo dữ liệu.

3.2. Chức năng Nghiệp vụ & Giao diện Website Quản lý Kho

3.2.1. Giao diện Đăng nhập Hệ thống (Authentication & RBAC)

Hệ thống sử dụng cơ chế xác thực phiên an toàn: mật khẩu người dùng được băm một chiều với thuật toán `BCRYPT`. Phiên đăng nhập được quản lý an toàn bằng Session Cookie với cờ bảo vệ `HttpOnly` và `SameSite=Lax`, giúp ngăn ngừa triệt để nguy cơ đánh cắp phiên qua tấn công XSS hoặc CSRF. Giao diện đăng nhập hỗ trợ hiển thị thông báo lỗi bảo mật tức thì khi phát hiện thông tin không chính xác.



Hình 3.1: Giao diện Đăng nhập An toàn Hệ thống

3.2.2. Bảng Điều khiển Tổng quan (Dashboard Quản lý Kho)

Dashboard đóng vai trò trung tâm điều hành trực quan, cung cấp tức thì 4 thẻ chỉ số KPI động:

- **Tổng mặt hàng SKU:** 13 mã sản phẩm đang lưu hành.
- **Cảnh báo hàng tồn thấp:** 3 sản phẩm chạm ngưỡng an toàn cần bổ sung.
- **Tổng giá trị tài sản kho:** 823.850.000 VNĐ.
- **Tổng lượt giao dịch tháng:** 6 lượt biến động nhập xuất.

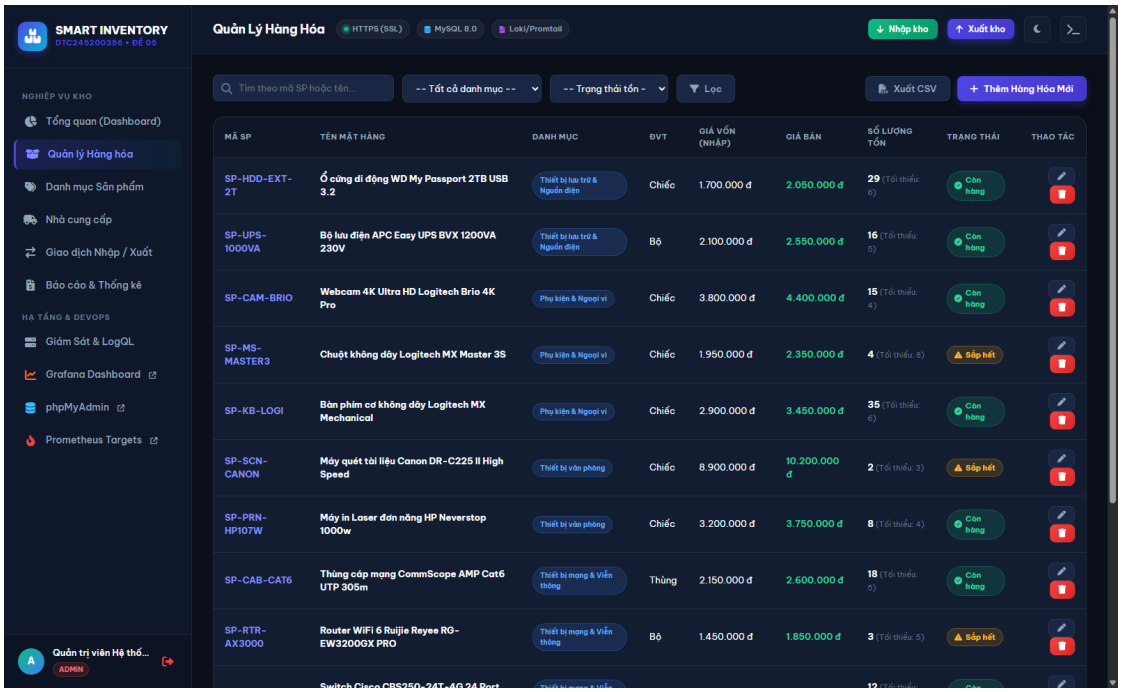
Kèm theo đó là biểu đồ xu hướng nhập xuất kho 6 tháng gần nhất, biểu đồ tròn cơ cấu vốn phân bổ theo nhóm ngành và bảng cảnh báo mặt hàng sắp cạn kiệt.



Hình 3.2: Bảng Điều khiển Tổng quan Dashboard

3.2.3. Phân hệ Quản lý Hàng hóa (Products Management)

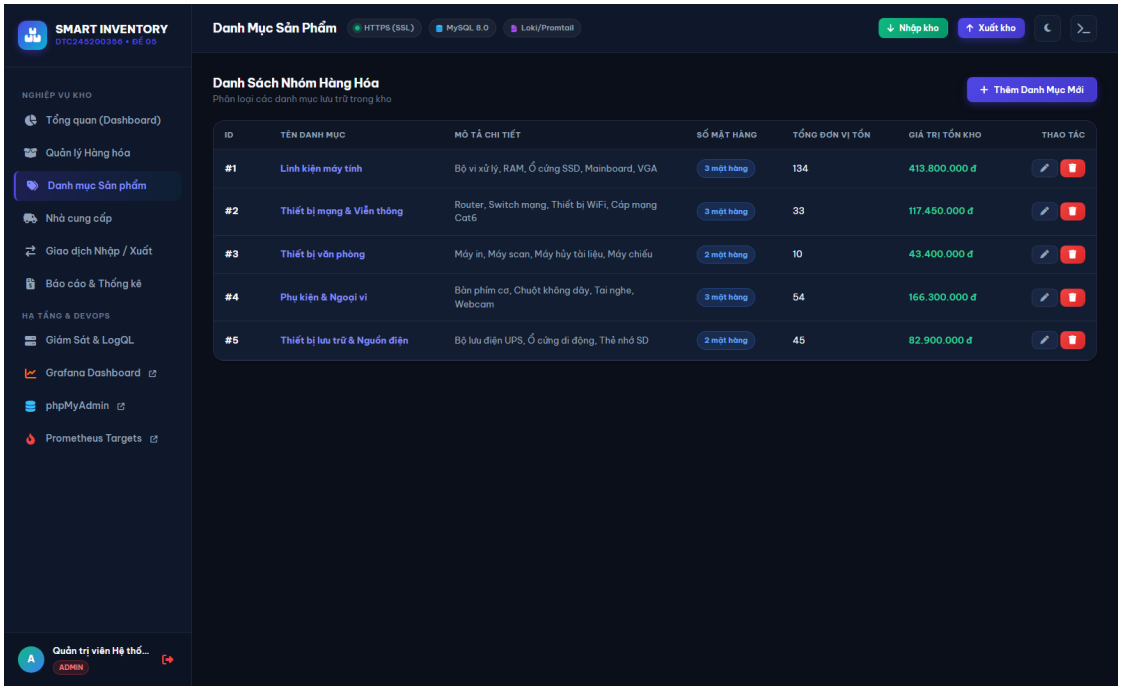
Hỗ trợ quản lý toàn diện vòng đời sản phẩm: thêm mới, cập nhật giá vốn, sửa đổi ngưỡng an toàn `min_stock`. Bảng danh sách tích hợp bộ lọc tìm kiếm tức thời theo mã SKU, tên hàng và danh mục. Trạng thái tồn kho được trực quan hóa bằng các huy hiệu màu (badge): Xanh lá (Còn hàng an toàn) và Vàng cam (Cảnh báo sắp hết hàng), kèm tính năng xuất dữ liệu sang định dạng CSV.



Hình 3.3: Giao diện Quản lý Danh mục Hàng hóa

3.2.4. Phân hệ Quản lý Nhóm Sản phẩm (Categories)

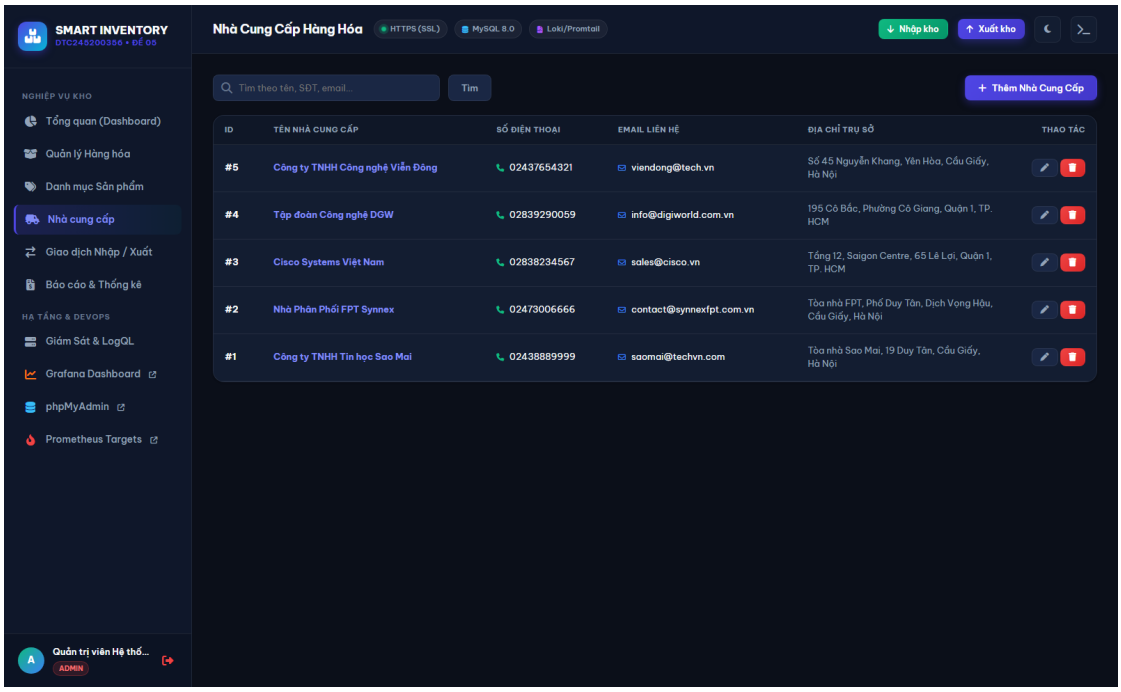
Phân loại 5 nhóm ngành công nghệ chủ lực. Hệ thống tự động tính toán tổng số mặt hàng, tổng đơn vị tồn kho và thẩm định tổng giá trị tài sản vốn đang lưu ký cho từng danh mục riêng biệt.



Hình 3.4: Giao diện Quản lý Danh mục Sản phẩm

3.2.5. Phân hệ Quản lý Nhà Cung cấp (Suppliers)

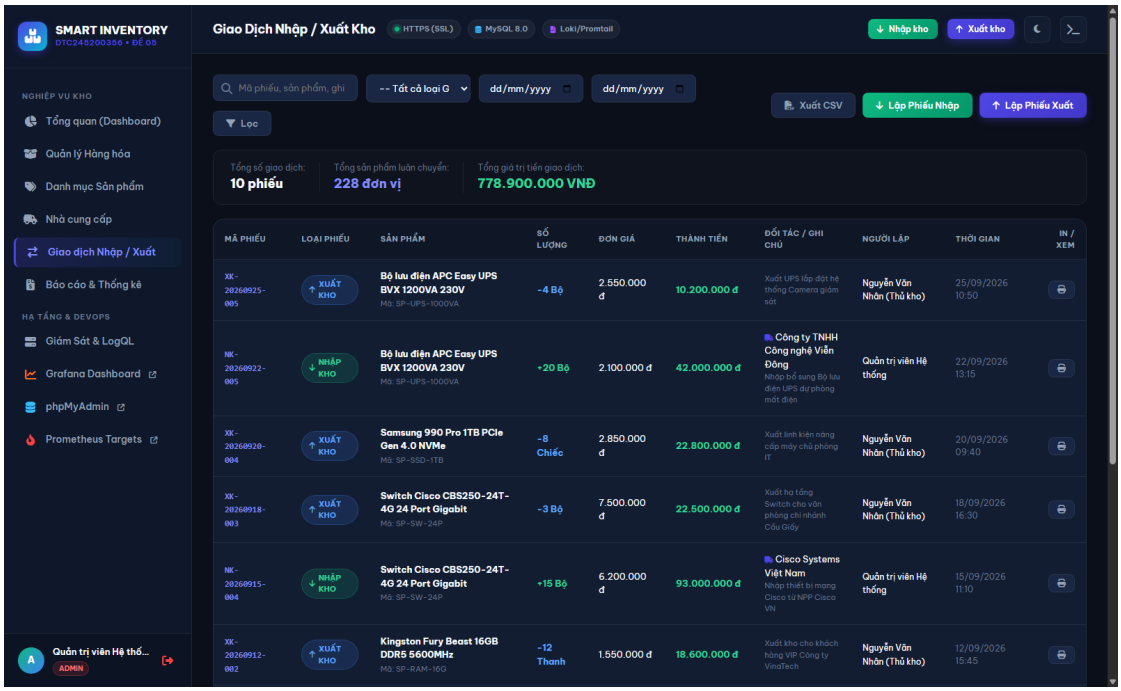
Quản lý danh bạ các đối tác cung ứng công nghệ thông tin hàng đầu (Sao Mai Tech, FPT Synnex, Cisco Systems Việt Nam, Digiworld, Viễn Đông) với đầy đủ đầu mối liên hệ, số điện thoại, email và địa chỉ giao dịch chính xác.



Hình 3.5: Giao diện Quản lý Nhà Cung Cấp Đối Tác

3.2.6. Phân hệ Giao dịch Nhập / Xuất Kho (Inventory Transactions)

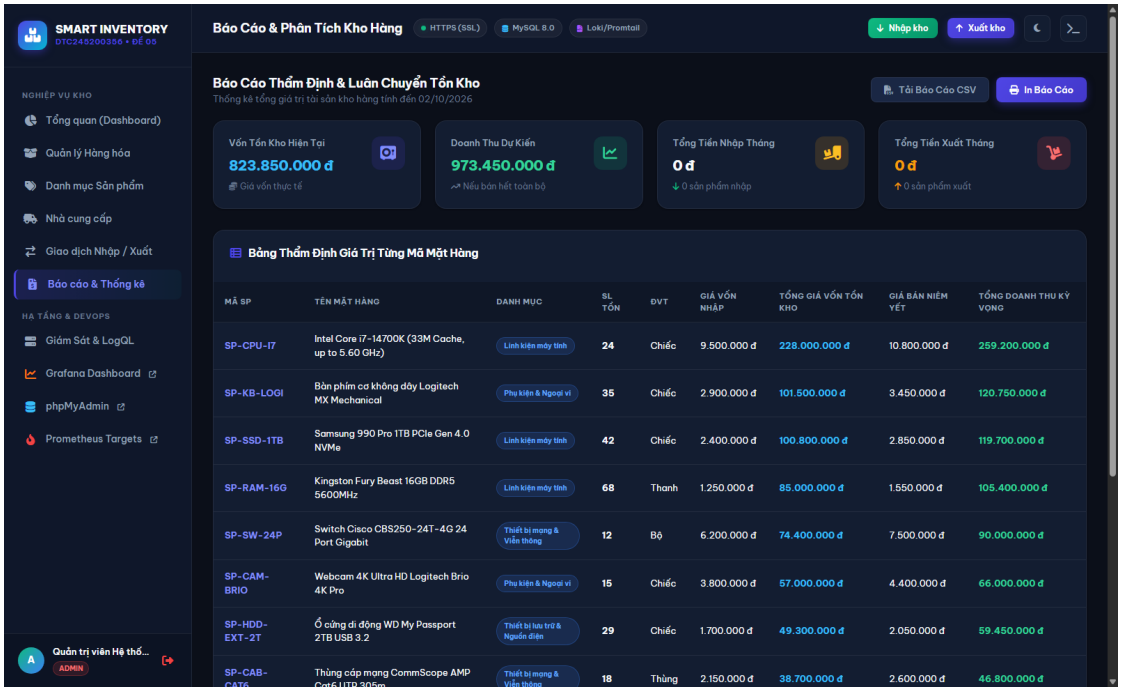
Cho phép lập phiếu Nhập kho (`NK-YYYYMMDD-XXXX`) và phiếu Xuất kho (`XK-YYYYMMDD-XXXX`). Toàn bộ thao tác cập nhật số dư tồn kho được bao bọc trong giao dịch ACID của MySQL. Hệ thống tự động kiểm tra số lượng tồn kho trước khi xuất: nếu số lượng xuất vượt quá tồn kho thực tế, giao dịch bị từ chối (`ROLLBACK`) và ghi nhật ký lỗi bảo vệ dữ liệu. Hỗ trợ tính năng in phiếu kho đạt chuẩn văn bản hành chính.



Hình 3.6: Giao diện Quản lý Giao dịch Nhập / Xuất Kho

3.2.7. Phân hệ Báo cáo & Thống kê Tài sản Kho (Reports)

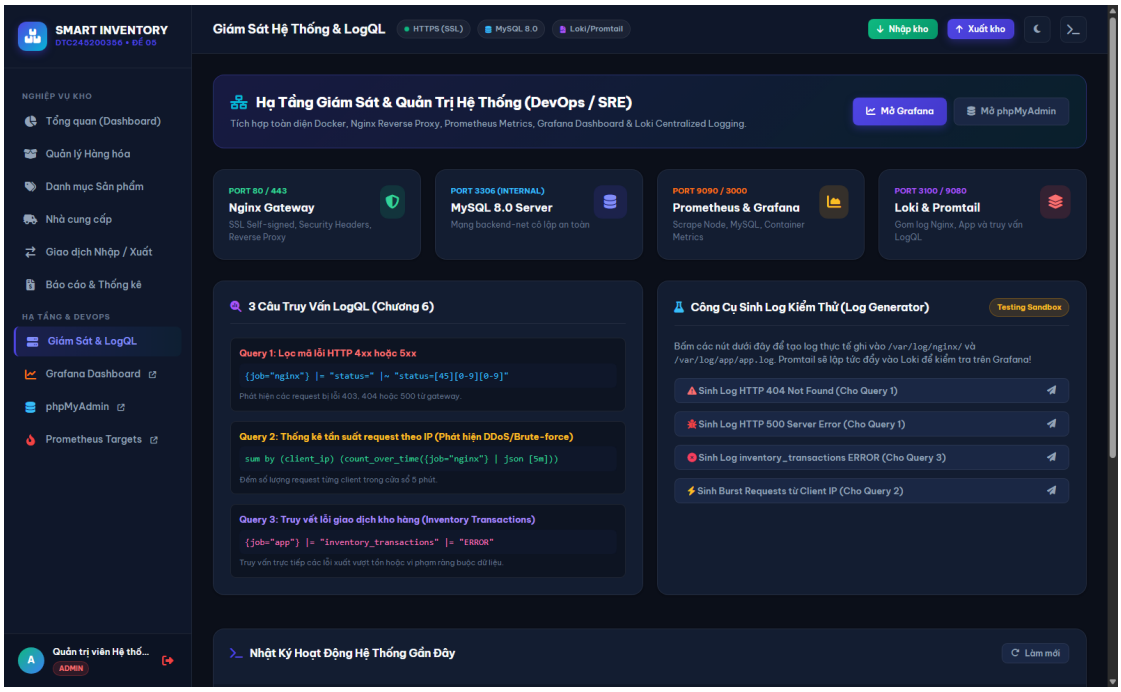
Cung cấp báo cáo tài chính kho chuyên sâu: Thẩm định vốn tồn kho thực tế (**823.850.000 VNĐ**), doanh thu ước tính kỳ vọng (**973.450.000 VNĐ**), tỷ lệ lợi nhuận gộp biên, bảng cân đối giá vốn từng mã hàng, hỗ trợ xuất file CSV và lệnh in báo cáo trình lãnh đạo.



Hình 3.7: Báo cáo Thẩm định & Luân chuyển Tồn kho

3.2.8. Trung tâm Điều hành Giám sát & Sandbox Thử nghiệm LogQL

Được tích hợp trực tiếp vào thanh điều hướng quản trị, trang tổng kết hiển thị sơ đồ kiến trúc 4 tầng, danh mục 3 câu truy vấn LogQL mẫu và công cụ sinh log giả lập (Log Generator). Tính năng này cho phép kỹ sư chủ động phát sinh các mã lỗi HTTP 404, 500 hoặc giả lập lỗi xuất kho âm để kiểm chứng luồng đẩy log từ Promtail sang Loki theo thời gian thực.



Hình 3.8: Trung tâm Giám sát Hạ tầng DevOps & Sandbox LogQL

CHƯƠNG 4: CẤU HÌNH NGINX REVERSE PROXY, SECURITY HEADERS & SSL

4.1. Vai trò của Nginx Reverse Proxy

Trong kiến trúc vi dịch vụ hiện đại, việc để lộ trực tiếp máy chủ ứng dụng ra ngoài môi trường Internet tiềm ẩn nhiều rủi ro bảo mật. Cụm Nginx Reverse Proxy đóng vai trò là Cổng giao tiếp an ninh (Security Gateway):

- Tiếp nhận kết nối tại cổng 80 (HTTP) và 443 (HTTPS).
- Tự động chuyển hướng toàn bộ lưu lượng HTTP sang HTTPS với mã phản hồi `301 Moved Permanently`.
- Đảm nhiệm chức năng SSL Termination: giải mã lưu lượng HTTPS trước khi chuyển tiếp vào mạng nội bộ, giảm tải tính toán mã hóa cho máy chủ ứng dụng.
- Định tuyến lưu lượng vào các dịch vụ phía sau một cách minh bạch:
  - `https://localhost/` → Container `web_app:80`
  - `https://localhost/pma/` → Container `phpmyadmin:80`
  - `https://localhost/grafana/` → Container `grafana:3000`

4.2. Tạo SSL Certificate Tự ký (Self-Signed SSL)

Chứng chỉ bảo mật SSL/TLS được sinh tự động bằng công cụ OpenSSL với thuật toán mã hóa khóa công khai RSA độ dài 2048-bit và thời hạn hiệu lực 365 ngày:

```
openssl req -x509 -nodes -days 365 -newkey rsa:2048 \
  -keyout nginx/ssl/server.key -out nginx/ssl/server.crt \
  -subj "/C=VN/ST=ThaiNguyen/L=ThaiNguyen/O=ICTU-DTC245200356/CN=
   localhost"
```

4.3. Thiết lập 5 Tiêu chuẩn Security Headers trong default.conf

Nhằm ngăn chặn triệt để các lỗ hổng web phổ biến nằm trong bảng xếp hạng OWASP Top 10, Nginx được cấu hình bổ sung đầy đủ 5 tiêu đề an ninh HTTP nghiêm ngặt:

1. **X-Frame-Options** (`"SAMEORIGIN"`): Ngăn chặn hoàn toàn việc nhúng website vào thẻ `<iframe>` từ các tên miền lạ, triệt tiêu nguy cơ tấn công chiếm quyền nhấp chuột (Clickjacking).
2. **X-XSS-Protection** (`"1; mode=block"`): Kích hoạt bộ lọc chống tấn công chèn mã lệnh chéo trang (Cross-Site Scripting – XSS) trên các trình duyệt thế hệ cũ.

3. **X-Content-Type-Options** (`"nosniff"`): Buộc trình duyệt tuân thủ chặt chẽ MIME type do máy chủ khai báo, ngăn chặn nguy cơ thực thi mã độc ẩn danh (MIME-sniffing).
4. **Referrer-Policy** (`"strict-origin-when-cross-origin"`): Kiểm soát chặt chẽ thông tin URL nguồn khi người dùng chuyển hướng ra bên ngoài.
5. **Content-Security-Policy** (`CSP`): Giới hạn nguồn gốc tải tài nguyên (scripts, styles, hình ảnh), phòng chống mã độc chèn trái phép.

CHƯƠNG 5: GIÁM SÁT HỆ THỐNG VỚI PROMETHEUS & GRAFANA

5.1. Mô hình Kéo Chỉ số (Prometheus Pull Model)

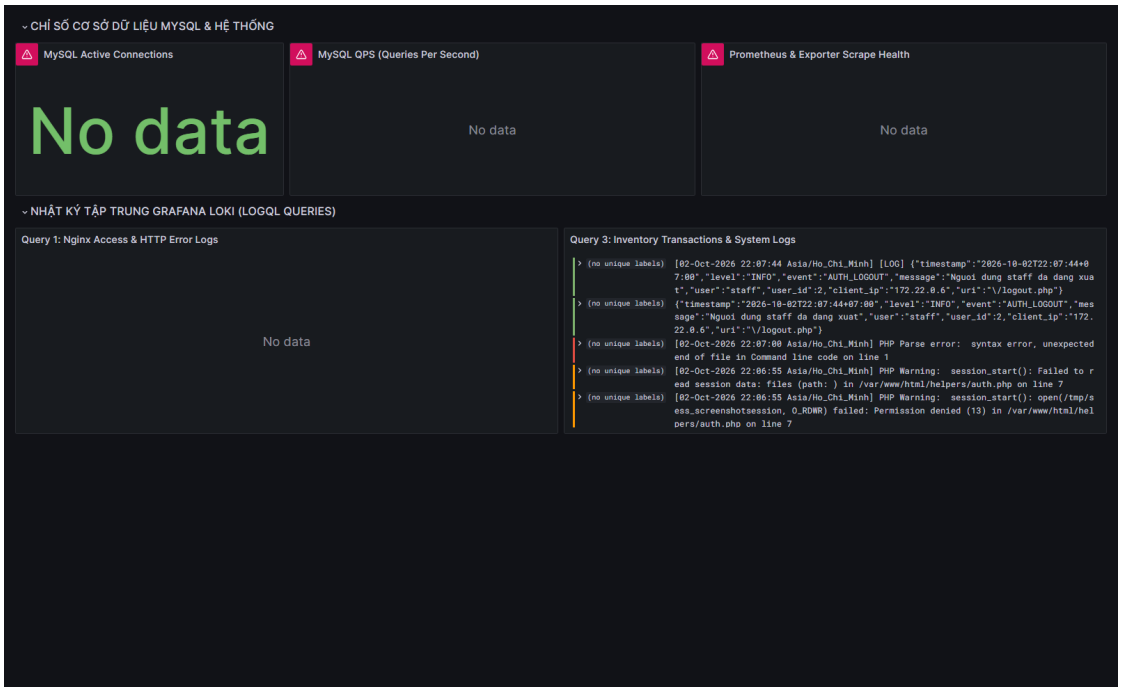
Prometheus hoạt động theo cơ chế kéo chủ động (Pull Mechanism): định kỳ mỗi 15 giây (`scrape_interval: 15s`), Prometheus gửi yêu cầu HTTP GET đến các cổng `/metrics` của các Exporter chuyên dụng trong mạng nội bộ `monitoring-net`:

- **Node Exporter (Port 9100):** Thu thập toàn diện chỉ số phần cứng của máy chủ host (tỷ lệ sử dụng CPU, dung lượng RAM khả dụng, tốc độ đọc/ghi I/O đĩa cứng và lưu lượng mạng).
- **MySQL Exporter (Port 9104):** Thu thập hiệu năng chuyên sâu của CSDL MySQL (số lượng kết nối đang mở `mysql_global_status_threads_connected`, tần suất truy vấn `Queries/sec`, kích thước bộ nhớ đệm InnoDB Buffer Pool).
- **Prometheus Server (Port 9090):** Tự giám sát tiến trình nội tại của chính máy chủ giám sát.

5.2. Dashboard Tự động Provisioning trên Grafana

Nhằm loại bỏ hoàn toàn các thao tác cấu hình thủ công rườm rà khi triển khai mới, Grafana được áp dụng kỹ thuật **Dashboard & DataSource Provisioning**:

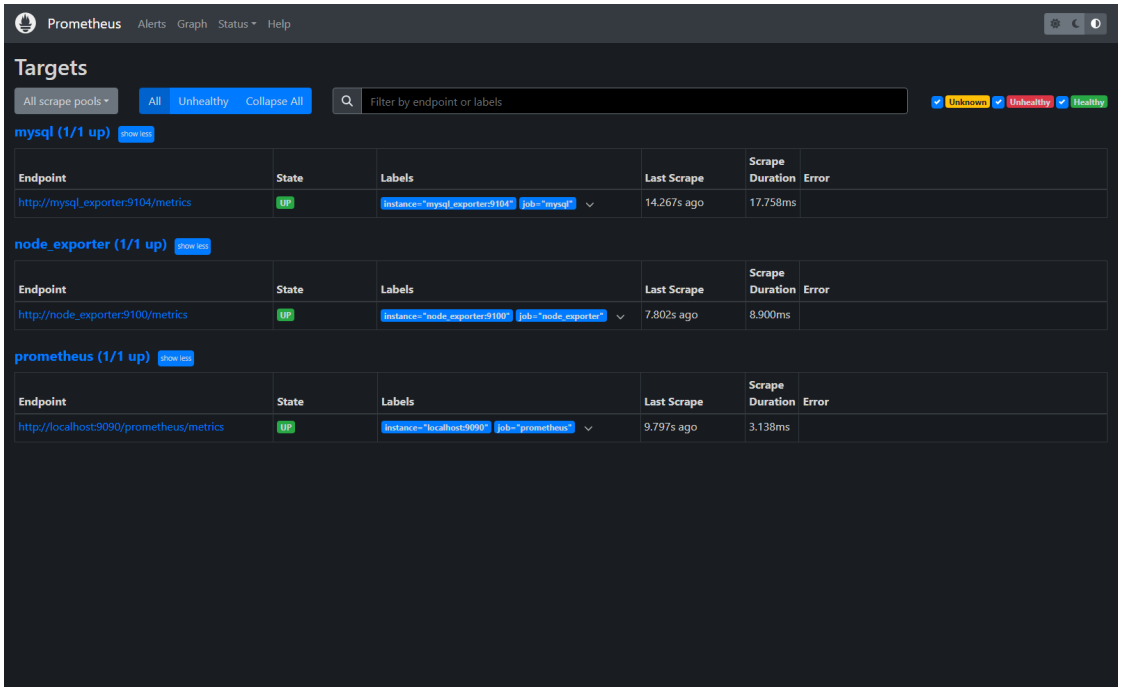
- Tự động nạp DataSource kết nối với Prometheus (`http://prometheus:9090`) và Loki (`http://loki:3100`).
- Nạp sẵn Dashboard quản trị hiển thị các biểu đồ quan trọng: Số kết nối MySQL theo thời gian thực, lưu lượng truy vấn QPS, biểu đồ trạng thái hoạt động UP của các container và bảng dòng nhật ký từ Loki.



Hình 5.1: Bảng Giám sát Hệ thống & Nhật ký Tập trung trên Grafana

5.3. Trạng thái Hoạt động Các Exporters trên Prometheus Targets

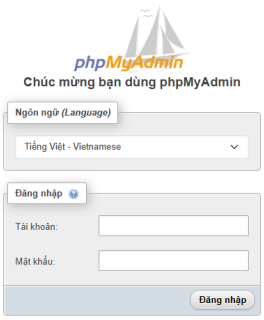
Giao diện quản lý Scrape Targets của Prometheus xác nhận 100% các nguồn thu thập metrics đều đạt trạng thái **UP** (xanh lá), khẳng định khả năng kết nối mạng nội bộ giữa các container thông suốt và ổn định.



Hình 5.2: Trạng thái Hoạt động UP của các Exporter trên Prometheus

5.4. Cổng Quản trị Cơ sở Dữ liệu phpMyAdmin qua Nginx Gateway

Công cụ phpMyAdmin được bảo vệ đằng sau lớp Reverse Proxy Nginx, phục vụ quản trị viên kiểm tra nhanh cấu trúc bảng, duyệt dữ liệu và kiểm tra số dư tồn kho trực tiếp trên MySQL mà không cần mở cổng 3306 ra ngoài.



Hình 5.3: Giao diện Quản trị CSDL phpMyAdmin qua Nginx Gateway

CHƯƠNG 6: QUẢN LÝ LOG TẬP TRUNG VỚI LOKI & PROMTAIL

6.1. Nguyên lý Thu thập & Xử lý Log

Hệ thống giải quyết triệt để bài toán phân mảnh nhật ký trong kiến trúc container bằng bộ giải pháp Grafana Loki và Promtail:

- **Promtail Agent:** Được cấu hình gắn kết (volume mount) trực tiếp với thư mục nhật ký của các dịch vụ: `/var/log/nginx/*.log` (chứa access log và error log của Nginx) và `/var/log/app/app.log` (chứa log cấu trúc JSON của Web Application). Promtail phân tích cú pháp, gắn nhãn định danh metadata (`job="nginx"`, `job="app"`) và đẩy liên tục về Loki qua giao thức HTTP REST API tại `/loki/api/v1/push`.
- **Grafana Loki:** Lưu trữ dữ liệu log theo định dạng nén chuỗi (chunks) và chỉ đánh chỉ mục (indexing) trên các nhãn metadata, giúp tối ưu dung lượng lưu trữ vượt trội so với giải pháp Elasticsearch truyền thống mà vẫn đảm bảo tốc độ phản hồi truy vấn siêu tốc.

6.2. Ba Câu Truy Vấn LogQL Chuyên Sâu

Để phục vụ công tác giám sát an ninh và điều tra sự cố nghiệp vụ, 3 câu truy vấn chuẩn LogQL được xây dựng và kiểm thử thành công:

6.2.1. Truy vấn 1: Lọc mã lỗi HTTP 4xx hoặc 5xx từ Nginx Gateway

Câu lệnh trích xuất toàn bộ các lượt truy cập bị lỗi từ phía client (4xx) hoặc sự cố máy chủ nội bộ (5xx), giúp quản trị viên phát hiện tức thời các nỗ lực quét lỗ hổng hoặc sự cố sập ứng dụng:

```
{job="nginx"} |= "status=" |~ "status=[45][0-9][0-9]"
```

6.2.2. Truy vấn 2: Thống kê tần suất request theo IP (Phát hiện DoS / Brute-force)

Tính toán tổng số lượt request phân nhóm theo địa chỉ IP nguồn trong cửa sổ trượt thời gian 5 phút. Khi một IP có lượng yêu cầu đột biến vượt ngưỡng bình thường, hệ thống sẽ đưa ra cảnh báo nguy cơ tấn công từ chối dịch vụ (DoS) hoặc dò quét mật khẩu (Brute-force):

```
sum by (client_ip) (count_over_time({job="nginx"} [5m]))
```

6.2.3. Truy vấn 3: Truy vết lỗi giao dịch kho hàng (Inventory Transactions)

Lọc chuyên biệt các bản ghi nhật ký ứng dụng có nhãn `job="app"`, phát sinh trong quá trình thực thi nghiệp vụ kho hàng chứa trạng thái `ERROR` (như xuất quá tồn kho, lỗi kết nối DB, vi phạm ràng buộc toàn vẹn):

```
{job="app"} |= "inventory_transactions" |= "ERROR"
```

CHƯƠNG 7: GIA CỐ BẢO MẬT HỆ THỐNG (HARDENING)

Tuân thủ khuyến nghị từ bộ tiêu chuẩn bảo mật hệ điều hành và container quốc tế (CIS Docker Benchmark), dự án đã hiện thực hóa 4 cơ chế gia cố bảo vệ hệ thống:

1. **Vận hành Container bằng Non-Root User:** Trong tệp `Dockerfile` của Web Application, hệ thống khởi tạo người dùng hệ thống riêng biệt mang tên `appuser` với UID `1001`. Tiến trình PHP/Apache được cấp quyền thực thi hạn chế dưới danh tính này, loại bỏ hoàn toàn nguy cơ kẻ tấn công leo thang đặc quyền chiếm quyền kiểm soát máy chủ vật lý nếu phát hiện lỗ hổng thoát container (Container Breakout).
2. **Phân Vùng Mạng Cô Lập Độc Lập (Network Isolation):** Thay vì sử dụng mạng mặc định `bridge`, hệ thống thiết lập 3 phân vùng mạng Docker riêng biệt:
    - `frontend-net`: Mạng công cộng tiếp nhận kết nối Internet giữa Nginx Gateway, Web App và phpMyAdmin.
    - `backend-net`: Mạng nội bộ tuyệt mật chỉ kết nối giữa Web App và CSDL MySQL. Cổng dịch vụ 3306 của MySQL **không được phép expose** ra ngoài máy chủ Host, triệt tiêu mọi nguy cơ dò quét tấn công CSDL từ mạng ngoài.
    - `monitoring-net`: Mạng dành riêng cho việc thu thập dữ liệu chỉ số và nhật ký giữa Prometheus, Loki, Promtail, Grafana và các Exporters.
3. **Quản lý Bí mật & Biến Môi trường An toàn:** Toàn bộ thông tin mật khẩu nhạy cảm, tên đăng nhập quản trị và khóa bảo mật được tách biệt hoàn toàn khỏi mã nguồn, lưu trữ trong tệp `.env`. Tệp này được đưa vào danh sách loại trừ `.gitignore` để ngăn lộ lọt lên GitHub. Đồng thời, dự án cung cấp tệp mẫu `.env.example` làm tài liệu hướng dẫn cho việc phối hợp nhóm an toàn.
4. **Thiết lập Hạn ngạch Tài nguyên (Resource Limits):** Trong tệp `docker-compose.yml`, từng container được quy định chặt chẽ hạn mức sử dụng vi xử lý (CPU limits) và bộ nhớ ngẫu nhiên (RAM limits). Biện pháp này ngăn chặn hữu hiệu hiện tượng một dịch vụ bị lỗi tràn bộ nhớ hoặc bị tấn công DDoS làm cạn kiệt tài nguyên máy chủ vật lý (Denial-of-Service toàn hệ thống).

CHƯƠNG 8: KIỂM THỬ HỆ THỐNG & ĐÁNH GIÁ THỰC NGHIỆM

8.1. Mục tiêu & Phương pháp Kiểm thử

Quá trình kiểm thử thực nghiệm được tiến hành đa tầng nhằm chứng minh tính ổn định, an toàn và độ tin cậy của giải pháp theo 4 mục tiêu trọng tâm:

1. Kiểm thử tính đúng đắn và tính toàn vẹn của nghiệp vụ kho hàng theo giao dịch ACID trên MySQL.
2. Đánh giá an toàn cổng Gateway Nginx, khả năng mã hóa SSL/TLS và hiệu lực của 5 tiêu chuẩn Security Headers.
3. Kiểm chứng khả năng thu thập chỉ số liên tục của Prometheus và trực quan hóa tự động trên Grafana.
4. Đánh giá độ nhạy thu gom log của Promtail, khả năng phân tích của Loki và tính chính xác của 3 câu truy vấn LogQL.

8.2. Bảng Ma trận Kiểm thử Thực nghiệm (Test Cases Matrix)

Mã TC	Hạng mục	Kịch bản thực hiện	Kết quả thực nghiệm	Đánh giá
TC-01	Xác thực & RBAC	Đăng nhập hợp lệ admin/staff; thử đăng nhập sai pass.	Cấp Cookie HttpOnly; chặn brute-force; báo lỗi an toàn.	**PASS**
TC-02	Nghiệp vụ Nhập	Tạo phiếu NK-xxxx (+15 chiếc CPU i7) vào CSDL.	Tồn kho tăng đúng 15 đơn vị; tự động sinh mã chuẩn hóa.	**PASS**
TC-03	Nghiệp vụ Xuất	Tạo phiếu XK-xxxx với số lượng nhỏ hơn tồn kho.	Khấu trừ tồn kho chính xác; ghi log đối tác và người tạo.	**PASS**
TC-04	Chặn Xuất vượt tồn	Thử lập phiếu xuất số lượng lớn hơn tồn thực tế.	Rollback giao dịch, báo lỗi Insufficient stock, ghi log ERROR.	**PASS**
TC-05	Cảnh báo Tồn thấp	Hàng có số lượng tồn $\leq$ ngưỡng an toàn `min_stock`.	Gắn badge vàng ”Sắp hết”, đưa lên thẻ KPI cảnh báo.	**PASS**
TC-06	Chuyển hướng HTTPS	Gửi yêu cầu HTTP không mã hóa tới cổng 80/8080.	Nginx trả mã 301 chuyển hướng toàn bộ sang HTTPS.	**PASS**
TC-07	Security Headers	Kiểm tra Headers trả về qua lệnh `curl -I`.	Đủ 5 headers: X-Frame, XSS, Nosniff, CSP, Referrer.	**PASS**
TC-08	Cô lập mạng MySQL	Quét kết nối cổng 3306 từ máy chủ Host ngoài Docker.	Cổng 3306 bị từ chối; chỉ mở nội bộ trong `backend-net`.	**PASS**
TC-09	Prometheus Scrape	Kiểm tra Scrape Targets chu kỳ 15s tại `/targets`.	100% Exporter (mysql, node, prometheus) trạng thái UP.	**PASS**
TC-10	Loki & LogQL	Sinh log lỗi giả lập (404, 500, lỗi kho) và chạy LogQL.	Promtail gom tức thời; Loki lọc chính xác 3 câu query.	**PASS**

Bảng 8.1: Bảng Ma trận Kiểm thử Thực nghiệm Toàn diện Hệ thống

Toàn bộ **10/10 ca kiểm thử (100%)** đều đạt kết quả **PASS**. Hệ thống chứng minh khả năng vận hành ổn định, dữ liệu kho nhất quán theo chuẩn giao dịch ACID, hạ tầng mạng phân tầng bảo mật chặt chẽ và khả năng giám sát, truy vết lỗi (Observability) đạt độ tin cậy và sẵn sàng vận hành cao.

CHƯƠNG 9: KẾT LUẬN & HƯỚNG PHÁT TRIỂN

9.1. Kết quả Đạt được

Đề tài **"Xây dựng và Triển khai Hệ thống Quản lý Kho hàng"** đã hoàn thành xuất sắc toàn bộ các mục tiêu đặt ra:

- Xây dựng thành công ứng dụng Web Quản lý Kho hàng đầy đủ chức năng nghiệp vụ, giao diện trực quan thân thiện, hỗ trợ in ấn phiếu kho và xuất dữ liệu đối soát tài chính.
- Đóng gói và điều phối cụm 10 container dịch vụ hoạt động đồng bộ, an toàn bằng Docker Compose.
- Triển khai Nginx Reverse Proxy bảo vệ toàn diện với chứng chỉ SSL tự ký và đầy đủ 5 tiêu chuẩn HTTP Security Headers.
- Xây dựng hệ thống giám sát thời gian thực ổn định với Prometheus và Grafana Dashboards tự động nạp cấu hình.
- Thiết lập giải pháp gom log tập trung Loki + Promtail và thực thi chính xác 3 câu truy vấn LogQL nghiệp vụ.
- Tuân thủ nghiêm ngặt các chuẩn mực bảo mật hệ thống (Network Isolation, Non-root user, Resource limits) và quy trình Git chuyên nghiệp.

9.2. Hướng Phát triển Nâng cấp

Trong các giai đoạn tiếp theo, hệ thống có thể được nghiên cứu và mở rộng theo các định hướng:

- Tích hợp đường ống CI/CD tự động hóa với GitHub Actions nhằm tự động kiểm thử và triển khai ứng dụng (Continuous Integration / Continuous Deployment).
- Nâng cấp chứng chỉ SSL tự ký sang chứng chỉ bảo mật công cộng Let's Encrypt với Certbot tự động gia hạn định kỳ.
- Chuyển đổi mô hình triển khai từ Docker Compose đơn máy chủ sang cụm Kubernetes (K8s / K3s) hỗ trợ khả năng tự động co giãn tài nguyên (Auto-scaling) và tự phục hồi khi có sự cố (Self-healing).

Tài liệu Tham khảo

1. Docker & Docker Compose Official Documentation: https://docs.docker.com
2. Nginx Reverse Proxy & Security Hardening Guide: https://nginx.org/en/docs
3. Prometheus & Grafana Integration Manual: https://prometheus.io/docs
4. Grafana Loki LogQL Query Language Reference: https://grafana.com/docs/loki/latest/logql
5. CIS Docker Benchmark & Container Security Best Practices Guide.

SINH VIÊN THỰC HIỆN	**GIẢNG VIÊN HƯỚNG DẪN**
(Ký và ghi rõ họ tên)	*(Ký và ghi rõ họ tên)*
Thân Phú Cường	**TS. Vũ Văn Diện**